



PAW

Lic. en Sistemas de Información

Trabajo Práctico Final

Integrador de Conocimientos

Grupo Cerberus

Integrantes:

Salvador Baez

Mateo Nomico

Tomás Resnik



PAW

Lic. en Sistemas de Información

Propuesta General de la Aplicación IndieCinema



indie
CINEMA

1. Descripción y objetivos

Descripción

IndieCinema es una plataforma web destinada a la organización de proyecciones de cine amateur e independiente. Cualquier usuario registrado puede solicitar el rol de organizador y, una vez que el equipo de moderación aprueba su solicitud y la documentación del espacio, dar de alta una sala indie, como un cineclub, un centro cultural, un espacio barrial o un evento puntual, para programar en ella funciones de películas o cortometrajes. Los espectadores, por su parte, pueden explorar las salas y la cartelera, seguir las salas y los organizadores que les interesan, votar qué títulos se proyectan en cada función, reservar sus lugares y, una vez finalizada la función, calificarla.

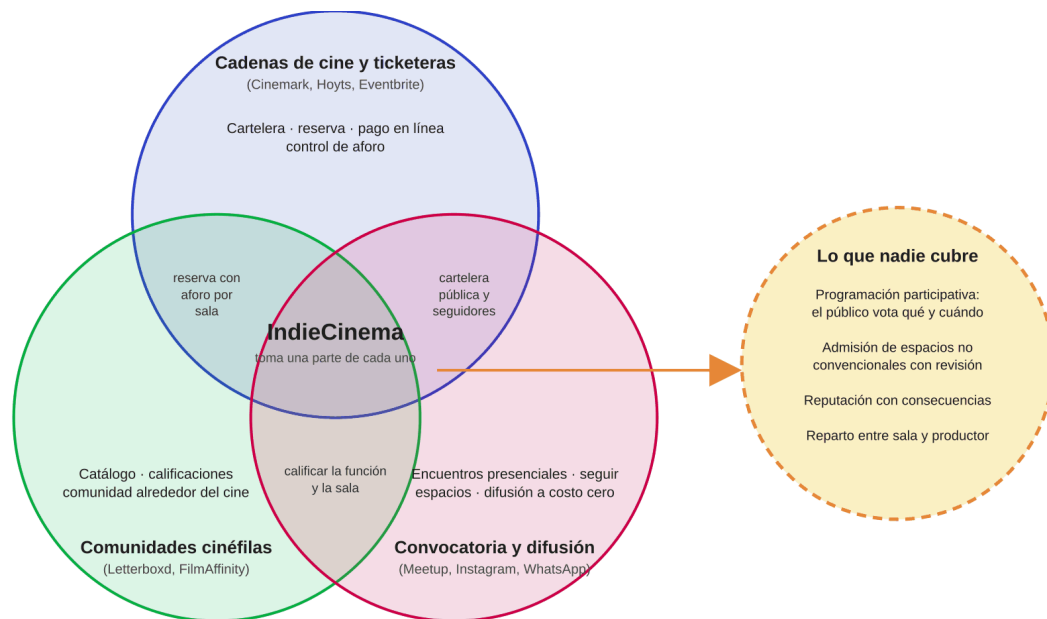


Para que la convivencia dentro de cada sala sea lo mejor posible, el organizador cuenta con herramientas de moderación que le permiten bloquear usuarios de su sala indicando el motivo (por ejemplo, “bloqueado por hablar durante la proyección”). El acceso a las mejores películas no es parejo: las salas mejor calificadas por el público obtienen prioridad para programar los títulos más pedidos, de modo que la calificación tenga una consecuencia concreta y no sea sólo informativa.

Análisis de la competencia

Hoy no existe una plataforma que cubra el circuito completo que propone IndieCinema. Las alternativas resuelven partes del problema, y de esa brecha sale nuestro diferencial.

Plataforma	Qué resuelve	Qué deja afuera
Cadenas de cine y sus apps (Cinemark, Hoyts)	Cartelera, reserva de butaca numerada y pago en línea.	el espectador no propone ni vota. Los espacios no comerciales no tienen lugar.
Eventbrite	Publicación de eventos, venta de entradas y control de aforo.	No hay catálogo de películas, ni votación de qué se proyecta, ni comunidad sostenida alrededor de una sala.
Meetup	Comunidades por interés y convocatoria a encuentros presenciales.	No modela funciones, catálogo, capacidad ni calificación de la proyección.
Letterboxd, FilmAffinity	Catálogo, calificaciones y comunidad cinéfila.	Trabaja sobre películas ya vistas: no organiza proyecciones presenciales ni reservas.
Instagram y WhatsApp, que es lo que usan hoy los cineclubes	Difusión, contacto directo con el público y costo cero.	Sin reservas ni control de capacidad, sin historial ni reputación; la fecha se coordina a mano en los comentarios.



El diferencial de IndieCinema son dos cosas que ninguna de las anteriores ofrece: la programación participativa, donde el espectador decide qué se proyecta y cuándo, y la habilitación de espacios no convencionales mediante un proceso de admisión y un sistema de reputación que hace que el público pueda confiar en una sala que no conoce.

Objetivo general

Desarrollar IndieCinema, una aplicación web que centralice la organización de proyecciones de cine amateur e independiente, conectando a los organizadores de salas indie con los espectadores interesados, y que facilite la elección participativa de las películas, la gestión de reservas y la retroalimentación de la comunidad sobre cada función. Queda pendiente de investigación el régimen de derechos de exhibición aplicable: bajo qué condiciones y cuántas veces puede proyectarse públicamente una obra adquirida, y qué diferencia hay entre una proyección sin fines comerciales y una con venta de entradas.

Objetivos específicos

- Permitir el registro y la autenticación de usuarios con roles diferenciados: espectador, organizador, moderador y administrador del sitio, y con un circuito de alta y revisión para el rol de organizador.
- Brindar a los organizadores un ABM de salas indie con parámetros configurables (ubicación, capacidad, cantidad de películas por función, duración de la función, etc.).
- Mantener un catálogo (ABM) de películas y cortometrajes disponibles para proyectar.
- Permitir que los espectadores voten qué películas o cortometrajes se proyectan en cada función, y también que propongan títulos que todavía no están en el catálogo para que una sala los levante.



- Gestionar la reserva de lugares para cada función, respetando la capacidad de la sala.
- Cobrar la entrada de cada función mediante una pasarela de pago externa, confirmando la reserva únicamente cuando el pago está acreditado.
- Habilitar la calificación de la función por parte de quienes asistieron y conservar el historial de proyecciones de cada sala junto con sus calificaciones.
- Permitir que los espectadores sigan salas y organizadores para enterarse de sus próximas funciones.
- Dar al organizador herramientas de moderación para bloquear usuarios de su sala, registrando el motivo.
- Proveer al administrador del sitio un panel para gestionar los usuarios, el catálogo global de películas y las estadísticas de uso.
- Someter el alta de cada sala a un proceso de admisión y revisión, con documentación obligatoria del espacio, para que el público pueda confiar en salas que no conoce.
- Coordinar la fecha y hora de cada función entre la sala y los espectadores interesados, y confirmarla sólo cuando se alcanza un mínimo de asistentes comprometidos.
- Sostener tres sistemas de puntuación (de películas, de salas y de espectadores) y que la puntuación tenga consecuencias concretas sobre lo que cada actor puede hacer en la plataforma. En el caso del espectador son dos medidas distintas. su conducta, que califica la sala, y su actividad, que surge de su historial de asistencias.
- Ofrecer un beneficio claro y explícito a cada actor del sistema, de modo que a todos les convenga usar la plataforma en lugar de coordinarse por fuera de ella.

Actores, responsabilidades y beneficios

Para cada actor del sistema se define qué se espera de él y, sobre todo, qué gana por participar. Si un actor no obtiene nada, termina coordinándose por fuera de la plataforma.

Actor	Responsabilidades	Qué gana
Espectador	Vota los títulos y la fecha, reserva su lugar, asiste, califica la función y respeta las normas de la sala.	Accede a películas y cortos que no están en la cartelera comercial y a un precio menor. Incide en qué se proyecta y cuándo. Acumula puntos por cada función a la que asiste, canjeables por descuentos en entradas siguientes o en comercios asociados. Recibe avisos sólo de las salas y los géneros que sigue.
Productor independiente	Carga su obra en el catálogo y autoriza su exhibición en las funciones que acepta. Declara ser titular de los derechos de exhibición de la obra que carga y	Consigue exhibición presencial y público real para una obra que de otro modo no llegaría a una sala, y recibe la calificación y los comentarios de quienes la vieron. Cobra un porcentaje del precio de cada entrada vendida para las funciones en que



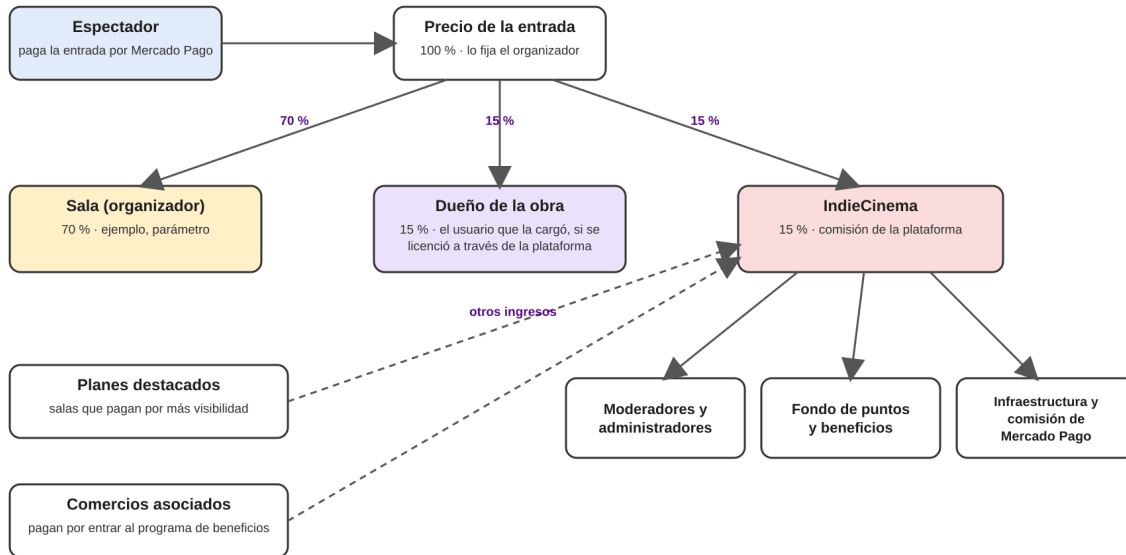
PAW

Lic. en Sistemas de Información

	acepta los términos y condiciones.	se proyecta su obra, según los parámetros de reparto de la plataforma.
Organizador de sala	Da de alta la sala, mantiene vigente su documentación, programa las funciones, controla el aforo.	Aprovecha un espacio que estaba ocioso y cobra por cada función. Usa la agenda, las reservas y el control de capacidad sin desarrollar nada propio, y llega a una audiencia ya formada. Si sostiene buena calificación, obtiene prioridad para levantar los títulos más pedidos del ranking.
Moderador	Revisa las solicitudes de alta de sala y su documentación, aprueba o rechaza con motivo, controla el vencimiento de las pólizas y atiende las denuncias.	Es un rol operativo de la plataforma. Su contraparte no es un beneficio comercial sino la confianza del sistema, que es lo que hace que espectadores y salas se sumen
Administrador	Gestiona usuarios y roles, mantiene el catálogo global, define los parámetros del sistema (umbrales, comisiones, vigencias) y consulta las estadísticas.	Visión completa del uso de la plataforma para ajustar las reglas y decidir sobre el catálogo compartido.
IndieCinema (la plataforma)	Sostiene el servicio, la moderación, el catálogo compartido y el programa de beneficios.	Se financia con una comisión sobre cada reserva paga, con planes destacados para las salas que quieren más visibilidad, y con los acuerdos con comercios asociados que pagan por integrar el programa de beneficios.

Reparto del dinero

Para que quede gráfico cómo circula la plata: el espectador paga la entrada por Mercado Pago; de ese monto una parte es de la sala, otra del dueño de la obra —el usuario que la cargó, cuando se licenció a través de la plataforma— y el resto es la comisión de IndieCinema, con la que se pagan moderadores y administradores, el fondo de puntos y la infraestructura. Los porcentajes son parámetros que fija el administrador; en el diagrama figuran valores de ejemplo (70 / 15 / 15). Las funciones gratuitas o a la gorra no generan reparto. A eso se suman los otros dos ingresos de la plataforma: los planes destacados de las salas y los comercios asociados.



Riesgos y mitigaciones

Buena parte de las decisiones de diseño de la aplicación responden a riesgos concretos del negocio.

Términos y condiciones: todo usuario los acepta al registrarse, el organizador vuelve a aceptarlos al solicitar su sala y quien carga una obra, al cargarla. Establecen que el organizador es responsable de la habilitación y la seguridad del espacio y de contar con los derechos de exhibición de cada obra que programa; que quien carga una obra declara ser titular de sus derechos; y que IndieCinema es un intermediario que no organiza las funciones ni responde por proyecciones o cobros realizados por fuera de la plataforma. Cada versión de los términos queda registrada junto con la fecha en que cada usuario la aceptó.

Riesgo	Impacto	Cómo lo mitigamos
Proyectar una obra sin la licencia de exhibición correspondiente.	Reclamo legal contra el organizador y contra la plataforma.	Al programar una función hay que declarar el origen de la copia. El catálogo distingue obra propia del realizador, obra de dominio público y título licenciado. El alcance real del régimen de derechos queda pendiente de investigar. Por términos y condiciones, la licencia es responsabilidad del organizador; la plataforma no responde por lo que se proyecta fuera del sitio.



PAW

Lic. en Sistemas de Información

Que una sala funcione en un espacio no habilitado o inseguro.	Un accidente durante una función, con responsabilidad civil sobre la plataforma.	Proceso de admisión con documentación obligatoria: seguro vigente, capacidad declarada y condiciones del espacio. La sala queda suspendida automáticamente cuando la póliza vence.
Contenido inapropiado cargado en el catálogo por un organizador o un realizador.	Daño reputacional y exposición legal.	El alta de títulos pasa por revisión de moderación antes de publicarse, y cualquier usuario puede denunciar una ficha o una función.
Funciones que se programan y no reúnen público.	El organizador pierde el costo de preparar la sala y deja de usar la plataforma.	La agenda participativa confirma la función recién cuando se alcanza el mínimo de reservas comprometidas; hasta ese momento la reserva no se cobra.
Reservas que no se presentan (no-show).	Lugares bloqueados que quedan vacíos y funciones que se caen por falso lleno.	La asistencia se registra por reserva y el historial de ausencias afecta la puntuación del espectador, que puede ver limitada la cantidad de reservas simultáneas.
No alcanzar masa crítica: sin público no hay salas y sin salas no hay público.	La plataforma no arranca.	Arranque focalizado en una localidad y sobre cineclubes ya existentes. El ranking de títulos pedidos permite mostrar demanda antes de que exista la oferta, que es lo que atrae a las primeras salas.



2. Presupuesto funcional

Se detallan a continuación las funcionalidades que incluirá la aplicación, agrupadas por módulo.

Módulo de Usuarios y Acceso

- **Registro e inicio de sesión:** alta de cuenta con validación de datos, inicio y cierre de sesión y recuperación de contraseña.
- **Roles:** Espectador, Organizador, Moderador y Administrador. Todo usuario se registra como espectador y puede solicitar el rol de organizador desde su perfil, que se le otorga recién cuando la solicitud pasa el proceso de admisión; el rol de administrador solo puede asignarlo a otro administrador desde el panel de administración. El rol de moderador lo asigna un administrador y habilita la bandeja de revisión de solicitudes.
- **Perfil de usuario:** edición de datos personales y foto, historial de reservas y de funciones calificadas, listado de salas y organizadores seguidos, y eliminación de cuenta. Para quien cargó obras al catálogo: listado de sus obras, dónde y cuándo se proyectó cada una, cuánto público la vio y cuánto le corresponde del reparto.
- **Página “¿Cómo funciona?”:** página informativa de contenido estático que explica a los usuarios nuevos el circuito de votación, reserva, asistencia y calificación.
- **Solicitud para ser organizador:** formulario con los datos del espacio (dirección, capacidad, tipo de sala, fotos, videos) y carga de la documentación obligatoria en PDF: seguro vigente y, cuando corresponda, habilitación municipal. El usuario sigue el estado de su solicitud desde el perfil y puede corregirla y volver a enviarla. El formulario pide además el detalle completo del equipamiento y las comodidades (tamaño y tipo de pantalla o proyector, sistema de sonido, tipo de butacas, cafetería o bar, accesibilidad) y un video.

Módulo de Moderación y Admisión

- **Bandeja de solicitudes (Moderador):** listado de las solicitudes de alta de sala pendientes, con su documentación adjunta y el historial del usuario que la presenta.
- **Revisión:** checklist de requisitos sobre cada solicitud (seguro vigente, capacidad declarada, condiciones del espacio) y resolución con aprobación o rechazo, siempre con el motivo registrado y visible para el solicitante. Si la documentación no alcanza para decidir, la solicitud pasa al estado de revisión manual: un moderador visita el espacio y confirma lo declarado.
- **Vigencia de la documentación:** cada documento tiene fecha de vencimiento; al vencer, la sala se suspende automáticamente y no puede programar funciones nuevas hasta actualizarlo.
- **Denuncias:** cualquier usuario puede denunciar una sala, una función o una ficha del catálogo. Las denuncias llegan a la misma bandeja y pueden derivar en la suspensión de la sala o en la baja del contenido.
- **Revisión del catálogo:** los títulos que carga un organizador quedan pendientes de aprobación antes de publicarse en el catálogo compartido.



PAW

Lic. en Sistemas de Información

- **Términos y condiciones:** el administrador publica versiones y el sistema registra qué versión aceptó cada usuario y cuándo (al registrarse, al solicitar una sala y al cargar una obra).

Módulo de Salas

- **ABM de salas (Organizador):** nombre, descripción, dirección y localidad, imágenes y capacidad. Incluye el detalle de equipamiento y comodidades: pantalla, sonido, butacas, servicios y accesibilidad.
- **Parámetros configurables por sala:** cantidad de películas por función, duración de la función, tiempo entre funciones, entre otros.
- **Categoría de sala:** estándar o VIP, asignada en la admisión a partir del equipamiento declarado y revisable según la calificación que reciba. Las salas VIP pueden exigir una puntuación de conducta mínima para reservar.
- **Listado público de salas:** buscador por nombre y localidad. Filtros por categoría y equipamiento.
- **Ficha de la sala:** información general, próximas funciones, historial de proyecciones realizadas y calificación promedio.
- **Seguimiento:** seguir o dejar de seguir a una sala o a su organizador.
- **Moderación:** bloqueo de usuarios de la sala con registro del motivo, listado de usuarios bloqueados y posibilidad de desbloquearlos. Un usuario bloqueado no puede votar ni reservar en esa sala.

Módulo de Catálogo de Películas

- **ABM de películas y cortometrajes (Organizador / Administrador):** título, tipo (película o cortometraje), sinopsis, duración, año, género, director y afiche. Cualquier usuario registrado puede cargar una obra propia: queda asociada a su dueño, que autoriza su exhibición y cobra su parte del reparto. La ficha suma la clasificación de contenido y el origen de la copia.
- **Listado del catálogo:** buscador y filtros por género, duración y tipo (película o cortometraje).
- **Ficha de la película:** información general, salas donde se proyectó y calificaciones recibidas.
- **Pedidos de títulos ausentes:** cuando un espectador no encuentra la película que busca, puede pedirla indicando título, año y director. Los pedidos se acumulan en un ranking ordenado por cantidad de votos y quedan activos al superar el umbral mínimo de interesados, configurable por el administrador.
- **Toma de un pedido:** un organizador puede tomar un pedido activo y comprometerse a conseguir el título y programarlo. Las salas mejor calificadas ven los pedidos y pueden tomarlos antes que el resto, que es el beneficio concreto que otorga la buena reputación.

Módulo de Funciones y Votación

- **ABM de funciones (Organizador):** sala, fecha y hora, películas propuestas y estado de la función (en votación, programada, finalizada o cancelada).
- **Votación:** mientras la función está en votación, los espectadores eligen entre las películas candidatas propuestas por el organizador. La votación cierra en la



fecha límite definida (o manualmente) y quedan seleccionados los títulos más votados, tantos como indique el parámetro de cantidad de películas por función de la sala. Los títulos candidatos salen del catálogo de la sala; para incorporar uno que no está, el camino es el ranking de pedidos del catálogo.

- **Circuito de estados:** al cerrarse la votación la función pasa a programada: desde ese momento ya no se puede votar y se habilita la reserva de lugares.
- **Cartelera:** listado de próximas funciones con filtros por sala, localidad, fecha y género.
- **Historial:** funciones realizadas por sala, con las películas proyectadas y su calificación.
- **Prioridad por reputación:** el orden en que las salas aparecen al buscar un título específico, se prioriza por reputación de sala (las salas con mas reputaciones aparecen antes que las de menos)

Módulo de Reservas

- **Reserva:** el espectador reserva uno o más lugares para una función programada. No hay selección de asiento: la sala no tiene distribución de ubicaciones y cada espectador se acomoda por orden de llegada.
- **Módulo de ping pong (acuerdo de fecha):** cerrada la votación de títulos, la función todavía no tiene fecha. El organizador propone dos o más franjas horarias posibles y los espectadores interesados votan cuál les sirve, comprometiendo su reserva. La función se confirma cuando la franja más votada alcanza el mínimo de asistentes que la sala definió, y se cancela si al llegar a la fecha límite ninguna lo alcanza. El circuito de estados de la función pasa entonces a ser: en votación de títulos, en acuerdo de fecha, programada, finalizada o cancelada.
- **Control de capacidad:** no se permite reservar más lugares que los disponibles; el usuario puede cancelar su reserva. La cantidad de lugares se fija al crear la función, y el disponible se calcula descontando las reservas pagas y las pendientes que todavía no vencieron.
- **Pago de la entrada:** el organizador fija el precio de cada función, que puede ser cero en las funciones gratuitas o a la gorra (Donación). El cobro se resuelve con Mercado Pago: el espectador es redirigido al entorno de pago de Mercado Pago, de modo que los datos de la tarjeta nunca pasan por la aplicación.
- **Estados de la reserva:** al reservar, el lugar queda retenido como pendiente de pago por un plazo acotado. La reserva se confirma cuando Mercado Pago notifica el pago acreditado, y si el plazo vence sin pago el lugar se libera y vuelve a estar disponible. La confirmación se toma siempre de la notificación del servicio, nunca del regreso del usuario al sitio, que puede no llegar a producirse.
- **Asistencia:** comprobante con código para presentar en la función; el organizador registra la asistencia de cada reserva.
- **Vista del organizador:** listado de reservas.
- **Recaudación:** el organizador consulta por función las entradas vendidas y el total recaudado.
- **Registro de reservas sin pagar:** las reservas sin pago registrado quedan como ausencia en el historial del espectador y Quedan registradas en su historial de



actividad, que limita cuántas reservas simultáneas puede tener abiertas; no tocan la conducta.

Módulo de Calificaciones

- **Calificación de la función:** puntaje de 1 a 5 y comentario opcional, habilitada una vez finalizada la función y solo para los usuarios que asistieron.
- **Promedios:** el puntaje se carga siempre sobre la función; a partir de esas calificaciones se derivan los promedios que se muestran por película, por sala y por organizador. El promedio de la sala alimenta el ranking de salas, que es el que define la prioridad para aparecer primero en las búsquedas.
- **Historial de proyecciones:** películas proyectadas con sus calificaciones, visible en la ficha de cada sala y de cada película.
- **Conducta del espectador:** al cerrar la función, el organizador puede calificar la conducta de cada asistente indicando el motivo (hablar durante la proyección, ensuciar, no respetar las normas de la sala). Funciona como el puntaje de una licencia de conducir: cada usuario arranca con el puntaje completo, las calificaciones negativas lo descuentan y, por debajo de un umbral, aparecen los punitivos: no puede reservar en salas VIP y tiene menos reservas simultáneas disponibles. Los puntos se recuperan con funciones a las que asiste sin incidentes.
- **Actividad del espectador:** es una medida distinta de la conducta: cuenta las funciones a las que asistió, las ausencias y las calificaciones que dejó. Alimenta el programa de puntos y beneficios y no penaliza.

Módulo de Beneficios

- **Puntos por asistencia:** cada función a la que el espectador asiste efectivamente le suma puntos, en función del valor de la entrada.
- **Canje:** los puntos se canjean por descuento en una entrada posterior o por beneficios de los comercios asociados, con el cupón emitido desde el perfil.
- **Comercios asociados (Administrador):** alta de comercios y de los beneficios que ofrecen, asociados a géneros o a localidades, para que lleguen a los espectadores a los que les pueden interesar.
- **Avisos por afinidad:** notificaciones de funciones nuevas filtradas por los géneros y las salas que el espectador sigue, en lugar de avisar de toda la cartelera.
- **Descuentos y promociones:** el organizador define descuentos por función (precio reducido para seguidores de la sala, dos por uno en funciones con baja demanda) y el administrador promociones por género o localidad junto con los comercios asociados.

Módulo de Recaudación

- **Parámetros de ganancia (Administrador):** comisión de la plataforma y porcentaje que corresponde al dueño de la obra, con fecha de vigencia para que un cambio no afecte funciones ya vendidas.
- **Reparto por función:** al cerrar cada función se calcula lo recaudado y se liquida: la parte de la sala, la del dueño de la obra y la comisión de IndieCinema.



- **Liquidaciones:** cada organizador y cada dueño de obra consulta lo que le corresponde por período. En el alcance del TP la transferencia del dinero se registra como realizada por el administrador; no se integra el modo marketplace de Mercado Pago.

Módulo de Reportería

- **Panel del organizador:** por función y por período: entradas vendidas, recaudación, asistencia real contra pagada (ausentes), calificaciones recibidas y conducta registrada.
- **Dueños de obra:** desde el perfil, dónde y cuándo se proyectó cada obra, cuánto público la vio, qué calificación recibió y cuánto le corresponde.
- **Panel del administrador:** métricas globales del sitio: salas y funciones activas, reservas y asistencias, títulos más votados, recaudación total y comisiones.

Módulo de Administración

- **Gestión de usuarios:** listado y búsqueda de usuarios, asignación del rol de administrador y suspensión o baja de las cuentas que incumplan las normas del sitio.
- **Catálogo global de películas:** ABM completo sobre el catálogo compartido, para corregir o unificar las fichas cargadas por los organizadores y dar de baja las duplicadas.
- **Estadísticas del sitio:** métricas agregadas de uso (salas y funciones activas, reservas y asistencias registradas, películas más votadas y calificaciones promedio). Recaudación total, comisiones y liquidaciones pendientes
- **Parámetros del sistema:** umbral de votos para activar un pedido de título, mínimo de asistencias para confirmar una función, vigencias de la documentación, equivalencia de puntos y comisión de la plataforma. Porcentajes de reparto entre sala, dueño de la obra y plataforma (con fecha de vigencia, para que un cambio no afecte funciones ya vendidas) y los umbrales de conducta que disparan los punitivos.
- **Asignación del rol de moderador** y seguimiento de la actividad de la bandeja de revisión.



3. Consideraciones de seguridad

La seguridad se analiza en cada entrega, en cada etapa del ciclo de vida y en cada capa del sistema: red, sistema operativo, motor de base de datos y aplicación. En esta primera entrega el análisis parte de qué hay que proteger y fija los controles que se van a implementar; en las siguientes, **esta sección se actualiza con lo que efectivamente se construyó, se desplegó y se probó.**

Qué hay que proteger

IndieCinema maneja cuatro tipos de activo con distinto valor para un atacante. Cada uno queda en un subsistema distinto (cuentas, moderación, programación, funciones y financiero) para que una vulnerabilidad en uno no alcance a los demás: es el criterio de mínimo privilegio y radio de daño con el que se partió la aplicación.

- **Credenciales y sesiones (cuentas):** contraseñas, cookies de sesión y roles. Quien las obtiene actúa como otro usuario, y si la cuenta es de un moderador o de un administrador, controla la plataforma.
- **Documentación y datos personales (moderación y cuentas):** pólizas de seguro, habilitaciones, domicilio del espacio, correo y teléfono. Son datos personales alcanzados por la Ley 25.326 de Protección de Datos Personales, así que se piden sólo los necesarios y se guardan sólo mientras sirven.
- **Dinero (funciones y financiero):** el estado de pago de cada reserva, el reparto, las liquidaciones y la credencial de Mercado Pago. Los datos de tarjeta no están entre los activos: con Checkout Pro se cargan en el sitio de Mercado Pago y nunca pasan por la aplicación, lo que reduce al mínimo las exigencias de PCI DSS.
- **Integridad de votos y puntuaciones (programación y funciones):** no son datos sensibles, pero tienen valor económico. La calificación de una sala le da prioridad sobre los títulos más pedidos y el puntaje de conducta habilita o bloquea reservas, así que hay incentivo para manipularlos con cuentas falsas o votos repetidos.

Seguridad por capa

La aplicación se despliega en un VPS con Docker Compose: nginx adelante, un contenedor PHP por subsistema y una instancia de MySQL 8 con un esquema por subsistema. Para cada capa se indican las amenazas principales y los controles previstos; las de la capa de aplicación siguen el OWASP Top 10.

Capa	Amenazas	Controles
Red	Intercepción de contraseñas y cookies de sesión. Acceso directo a la base o a las APIs internas desde Internet. Fuerza bruta sobre el inicio de sesión. Avisos de pago falsificados y	Cifrado en tránsito: HTTPS obligatorio con certificado de Let's Encrypt, redirección de HTTP y HSTS. Superficie mínima: el firewall del VPS sólo abre los puertos 80, 443 y SSH. La base y los contenedores PHP están en la red interna del compose: desde Internet sólo se alcanza nginx, que no publica las rutas /interno/ y descarta las cabeceras X-Usuario-* que



PAW

Lic. en Sistemas de Información

Capa	Amenazas	Controles
	saturación del webhook o de la cartelera pública.	lleguen de afuera. Límite de intentos: nginx limita por IP el inicio de sesión, el registro, los votos y el webhook de pago. Avisos de pago: el webhook de Mercado Pago se acepta sólo si la firma de la cabecera x-signature es válida.
Sistema operativo	Vulnerabilidades sin parchear en el sistema o en las imágenes de los contenedores. Acceso por SSH con una contraseña adivinada o robada. Un servicio comprometido que lee archivos o secretos de otro. Pérdida del servidor.	Parches: distribución con soporte de largo plazo, actualizaciones de seguridad automáticas e imágenes oficiales reconstruidas en cada entrega. Acceso administrativo: SSH sólo con clave pública, sin ingreso como root y con fail2ban. Aislamiento: cada contenedor corre con un usuario sin privilegios y monta sólo sus volúmenes. La documentación de las salas vive en el volumen de moderación, fuera del webroot. Secretos: los archivos de configuración no se versionan y sólo los lee el servicio que los usa; la credencial de Mercado Pago existe únicamente en funciones. Respaldos: diarios, de la base y de los archivos subidos, cifrados y guardados fuera del VPS.
Motor de base de datos	Inyección SQL. Un subsistema comprometido que lee o modifica los datos de otro. Borrado o alteración masiva de datos. Filtración de un respaldo.	Mínimo privilegio: un usuario de MySQL por subsistema, con permisos sólo sobre su esquema. Lo que otro subsistema necesita leer se publica como vista de sólo lectura. Sin permisos de estructura: el usuario con el que corre la aplicación no puede crear, alterar ni borrar tablas; las migraciones usan otro usuario. Sin exposición: MySQL no escucha fuera de la red interna del compose. Reglas en la base: claves únicas que sostienen las reglas aunque falle el código: un voto por usuario y función, y un único registro por identificador de pago, para que un aviso repetido no confirme dos veces. Restauración probada: antes de cada entrega se restaura un respaldo en una base limpia.
Aplicación	Control de acceso roto: un organizador que edita la sala de otro o un espectador que entra	Autenticación propia: sin servicios llave en mano. Contraseñas con password_hash y Argon2id; cookie de sesión HttpOnly, Secure y SameSite; identificador



Capa	Amenazas	Controles
	a rutas de moderación. Inyección, XSS y CSRF. Robo de sesión. Archivos maliciosos cargados como documentación. Confirmación falsa de un pago. Manipulación de votos y puntuaciones con cuentas falsas.	regenerado al iniciar sesión; recuperación de contraseña con un token de un solo uso que vence. Autorización en cada petición: rol mínimo por ruta y, además, verificación de que el recurso pertenece al usuario. Entrada y salida: consultas preparadas, autoescape de Twig y token CSRF en todo formulario. Archivos: validados por contenido y tamaño, renombrados al azar y entregados por un controlador que verifica el rol. Pagos: la reserva se confirma sólo con el aviso de Mercado Pago más una consulta a su API, verificando que el monto coincida; nunca por el regreso del usuario al sitio. Votos y puntuaciones: correo validado para votar y reservar, y sólo quien asistió califica. Auditoría: registro de los cambios de rol, las decisiones de moderación y las liquidaciones, sin datos personales en los logs.

Seguridad en cada etapa del ciclo de vida

Cada etapa del desarrollo tiene su parte de seguridad, y cada una cae en una entrega concreta. Así la seguridad no queda como una revisión al final, cuando cambiar el diseño ya es caro.

Etapas	Qué se hace	Entrega
Análisis y propuesta	Identificación de activos, actores y amenazas: esta sección y la tabla de riesgos. Requisitos que salen de ese análisis: autenticación propia, cobro con Checkout Pro para no manejar tarjetas, admisión de salas con documentación y datos personales mínimos.	1
Diseño	División en subsistemas por mínimo privilegio y radio de daño; qué datos guarda cada uno y qué ve cada usuario de base. Matriz de permisos por rol y por ruta. Modelo de amenazas de los dos circuitos críticos: el pago (aviso falso, aviso repetido, dos personas por el último lugar) y la admisión de salas (documentación falsa o vencida).	2



PAW

Lic. en Sistemas de Información

Etapa	Qué se hace	Entrega
Desarrollo	Controles de la capa de aplicación de la tabla anterior.	
	Revisión cruzada de cada cambio antes de integrarlo, con una lista de verificación de seguridad.	
	Ningún secreto en el repositorio: se versiona un archivo de configuración de ejemplo.	3 y 4
	Dependencias fijadas con composer.lock y revisadas con composer audit.	
Pruebas	Control de acceso por rol: un espectador contra rutas de organizador, un organizador contra la sala de otro.	
	Webhook de pago con avisos falsificados, repetidos y fuera de orden.	3 y 4
	Carga de archivos que no son PDF o que superan el tamaño permitido.	
	Análisis del sitio desplegado con OWASP ZAP antes de cada entrega.	
Despliegue	Endurecimiento del VPS en las capas de red, sistema operativo y base de datos.	
	Script de creación de la base con los usuarios y sus permisos, que corre sin condiciones previas del entorno.	3 y 4
	Errores de PHP ocultos al usuario y registrados en el log.	
	La guía de instalación documenta cada configuración de seguridad.	
Operación y mantenimiento	Actualizaciones del sistema y de las dependencias, respaldos con restauración probada y revisión de los registros de auditoría.	
	Rotación de la credencial de Mercado Pago y de los tokens entre subsistemas.	Desde la 3
	Ante un incidente: suspender la cuenta o la sala, invalidar sus sesiones y rotar los secretos expuestos.	



4. Presupuesto temporal

Estimación de horas de trabajo por tarea para el equipo de tres integrantes, separada en bloques e indicando en qué entrega cae cada tarea, según el cronograma de la cátedra: Entrega 1 el 31/08, Entrega 2 el 14/09, Entrega 3 el 19/10 y Entrega 4 el 09/11.

Tarea	Entrega	Horas
Análisis y diseño		-
Propuesta, presupuestos, análisis de competencia y sitemap	1	10
Wireframes del sitio y de los formularios de administración	2	10
Arquitectura, división en subsistemas y modelo de objetos	2	10
Diseño de la base de datos y scripts SQL	3	14
Subtotal de análisis y diseño		44
Desarrollo		-
Infraestructura base: MVC, Twig y configuración externalizada	3	16
Registro, autenticación, sesiones y roles	3	12
ABM de salas indie y parámetros configurables	3	8
ABM del catálogo de películas	3	6
Funciones, cartelera y votación de títulos	3	18
Reservas, control de capacidad y registro de asistencia	3	18
Solicitud y admisión de salas, con carga y revisión de documentación	4	16
Perfil de usuario y seguimiento de salas y organizadores	3	8
Pedidos de títulos pendientes y ranking de pedidos	4	12
Acuerdo de fecha y confirmación por mínimo de asistentes	4	15
Calificaciones, promedios y ranking de salas	4	12
Programa de puntos y beneficios	4	10
Panel de moderación y bandeja de revisión	4	10



PAW

Lic. en Sistemas de Información

Panel de administración y estadísticas	4	10
Integración con Mercado Pago: creación del cobro y redirección al pago	3	12
Notificación de pago: validación de firma, confirmación contra la API y procesamiento idempotente	3	12
Estados de la reserva, retención del lugar y liberación por vencimiento	3	16
Obras con dueño: carga por cualquier usuario, autorización y liquidación al dueño	3	6
Equipamiento y categoría de sala, revisión manual y clasificación de contenido	4	10
Conducta del espectador: calificación por el organizador, umbrales y punitivos	4	8
Módulo beneficio: parámetros de ganancia, reparto por función y liquidaciones	4	12
Reportería para organizador, dueños de obra y administrador	4	6
Descuentos y promociones	4	6
Subtotal de desarrollo		254
Diseño visual y front-end		-
Identidad visual, maquetado y hojas de estilo	3	16
Componentes propios en JavaScript (carrusel, filtros, arrastrar y soltar)	3	14
Subtotal de diseño visual y front-end		30
Integración, pruebas y despliegue		-
APIs internas entre cuentas, programación y funciones	3	12
Pruebas y QA del conjunto mínimo	3	8
Pruebas del circuito de pago con credenciales y usuarios de prueba	3	8
Seguridad: endurecimiento del VPS, usuarios de base con mínimo privilegio y análisis con OWASP ZAP	3	8
Despliegue público de nginx, MySQL, cuentas, programación y funciones, con guía de instalación	3	16
APIs internGHGas de moderación y financiero	4	8
Pruebas y QA de las funcionalidades de la Entrega 4	4	8
Seguridad: pruebas de control de acceso de moderación y financiero y nuevo análisis con OWASP ZAP	4	4



PAW

Lic. en Sistemas de Información

Despliegue de moderación y financiero y actualización de la guía de instalación	4	10
Subtotal de integración, pruebas y despliegue		82
Total estimado		415

Horas por entrega

Sumando las tareas de cada entrega y repartiéndolas en las semanas disponibles entre una fecha y la siguiente se ve si el presupuesto entra en el calendario.

Entrega	Fecha	Período de trabajo	Semanas	Horas
1	31/08	24/08 – 31/08	1	10
2	14/09	01/09 – 14/09	2	20
3	19/10	15/09 – 19/10	5	228
4	09/11	20/10 – 09/11	3	157
Total			11	426



5. Sitemap

El siguiente sitemap inicial presenta la estructura de navegación propuesta para el sitio. Las secciones de acceso público pueden consultarse sin iniciar sesión; el resto requiere un usuario registrado con el rol indicado en la referencia. La referencia de colores ordena las secciones por nivel de acceso: lo que ve el administrador incluye lo que ve el moderador, que incluye lo que ve el organizador, que a su vez incluye lo que ve el espectador registrado y lo que es público.

<https://whimsical.com/sitemap-paw/sitemap-inicio-Nm6maVHKLF9b8ueBeWB>



PAW

Lic. en Sistemas de Información

